ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Ubuntu Linux (LTS) · Component type: **Host Device (HDR) - server / EWS / OWS** · Target SL = SL 3

Where to work	**Shell** (SSH/console) as an authorized least-priv user with `sudo`; config in **/etc** (`/etc/ssh/sshd_config`, `/etc/security/*`, `/etc/audit/*`); `systemctl`, `ufw`, `auditctl`. Baseline against the **CIS Ubuntu Benchmark** / **DISA Ubuntu STIG**.
Interfaces / ports	SSH **22**; only required app ports open. Disable telnet/FTP/rsh/rlogin. Management via SSH/console.
Notes	HDR (host / EWS/OWS/server). Confirm release (`lsb_release -a`) and LTS support. Most controls verified read-only via config files + `systemctl`/`auditctl` state.
How to read	Default read-only (read config + query state). Native how-to + external-tool validation + pass. Scan/exploit tools = **authorized**; write/exploit = isolated env.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.1	Human user I&A;	SSH: `sshd -T | grep -E "permitrootlogin|permitemptypasswords|passwordauthentication"` -> `PermitRootLogin no`, `PermitEmptyPasswords no`; local accounts in `/etc/passwd` (no UID-0 besides root; no empty `/etc/shadow` fields); LDAP/SSSD where used. **Test:** root SSH denied; no anonymous/blank-password login. **Ext. tools:** ssh-audit; Lynis; OpenSCAP (CIS/STIG).	All logon authenticates; root SSH disabled; no empty passwords.	HDR.
SR/CR 1.2	Software process / device identification	Confirm daemons run as dedicated non-root service accounts (systemd `User=` / `DynamicUser=`), not shared; machine identity via host cert / 802.1X (wpa_supplicant) where used. **Ext. tools:** systemctl show (User=); ps -eo user,cmd review.	Services run under dedicated identities; unique host identity.	
SR/CR 1.3	Account management	Review `getent passwd` / `getent group sudo`; remove/disable unused & system-login accounts (`nologin`); expire stale (`chage -l`). **Ext. tools:** Lynis; OpenSCAP; `getent`	Named, least-priv accounts; no stale/shared; service accounts non-login.	
SR/CR 1.4	Identifier management	Confirm unique UIDs in `/etc/passwd`, no shared logins, root login disabled, unused/system accounts locked (`passwd -l` / nologin shell); lifecycle managed (LDAP/SSSD or config mgmt). **Ext. tools:** awk -F: on /etc/passwd (dup UID/UID 0); pwck.	Unique UIDs; root/shared logins disabled; accounts lifecycle-managed.	
SR/CR 1.5	Authenticator management	PAM `pam_pwquality` in `/etc/security/pwquality.conf` (minlen=14, dcredit/ucredit/ocredit/lcredit); `/etc/login.defs` PASS_MAX_DAYS/MIN/WARN; SHA-512 hashing in `/etc/shadow`. **Ext. tools:** OpenSCAP/CIS scan; config review.	Strong password policy (length/complexity/age) enforced via PAM.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Confirm host/service certificates are CA-issued and valid; trust store (`/etc/ssl/certs`, `update-ca-certificates`) holds only approved CAs; SSH host keys managed; no self-signed on exposed services. **Ext. tools:** openssl x509 -noout -dates; trust store review.	CA-issued, valid, revocable certificates; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm strong crypto: SSH uses ed25519/RSA-3072+ keys and strong ciphers/MACs/KEX (`sshd_config` Ciphers/MACs/KexAlgorithms), TLS 1.2/1.3 only; system crypto policy hardened. **Ext. tools:** ssh-audit; testssl.sh on exposed services.	Strong key/cipher policy; weak algorithms disabled.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.10	Authenticator feedback	Confirm password entry is not echoed (PAM default) and no password prompts leak; login banners do not reveal system details before auth. **Ext. tools:** Visual login test; PAM config review.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	`pam_faillock` in `/etc/security/faillock.conf` (deny=5, unlock_time=900, fail_interval); optionally `fail2ban` for SSH. **Test:** exceed the threshold -> account/IP locked; `faillock` shows the count. **Ext. tools:** Hydra (ISOLATED, authorized) to confirm faillock/fail2ban; `faillock` review.	Lockout after few failed attempts; brute force throttled.	
SR/CR 1.12	System use notification	Set `/etc/issue`, `/etc/issue.net`, and SSH `Banner /etc/issue.net` to the approved notice; confirm it shows at console/SSH login. **Ext. tools:** CIS scan; login visual check.	Approved banner displayed before login on console + SSH.	
SR 1.13	Access via untrusted networks	Harden SSH (key-based, MFA via `pam_google_authenticator`/SSSD); `ufw` restrict SSH to mgmt subnets; `fail2ban`; VPN for remote. **Test:** SSH from untrusted -> blocked/needs MFA. **Ext. tools:** Nmap (22 reachability by segment); `ufw status verbose`	Remote access key/MFA-based and restricted to mgmt networks.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.1	Authorization enforcement	Least-privilege `sudo`: review `/etc/sudoers` + `/etc/sudoers.d/*` (`visudo -c`) for broad NOPASSWD/ALL; check critical file perms/ownership; **AppArmor** profiles enforcing. **Test:** a standard user cannot perform admin actions. **Ext. tools:** Lynis; `sudo -l` as user; `aa-status`	Least privilege enforced (sudo + AppArmor); no broad NOPASSWD.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control removable media: **USBGuard** allow-list, mount options (`noexec,nosuid,nodev`) for removable mounts, or disable USB storage (blacklist `usb-storage` module) per policy. **Ext. tools:** usbguard list-devices; lsmod / modprobe config review.	Removable-media use controlled; unauthorized devices blocked.	
SR/HDR 2.4	Mobile code	Restrict untrusted/mobile code: **AppArmor** (or SELinux) confinement enforced, `fapolicyd` / execution allow-listing, `noexec` on /tmp and removable media; no interpreters exposed to untrusted input. **Ext. tools:** aa-status (enforce mode); mount options review.	Only trusted code executes; untrusted mobile code confined/blocked.	HDR-specific.
SR/CR 2.5	Session lock	Shell idle timeout `TMOUT` in `/etc/profile.d/`; desktop screen-lock where GUI. Confirm effective. **Ext. tools:** Config review; manual idle test.	Idle sessions time out / lock.	
SR/CR 2.6	Remote session termination	Confirm SSH idle timeout (`ClientAliveInterval/ClientAliveCountMax`), shell `TMOUT`, and login grace time; sessions terminable (`pkill -u` / loginctl). **Ext. tools:** sshd_config review; who / loginctl (active sessions).	Remote sessions time out and are terminable on demand.	
SR/CR 2.7	Concurrent session control	Limit concurrent logins via `/etc/security/limits.conf` (`maxlogins` / `maxsyslogins`) and PAM; monitor active sessions. **Ext. tools:** limits.conf review; w / loginctl.	Concurrent sessions limited per policy.	
SR/CR 2.8	Auditable events	**auditd** running with rules (`auditctl -l`, `/etc/audit/rules.d/`) for logins, sudo, identity/privilege, and critical-file changes; forward `rsyslog`/journald to the SIEM. **Test:** a sudo/login event is recorded. **Ext. tools:** OpenSCAP (audit rules); `ausearch`; SIEM check.	Security events audited (auditd) with user + time; forwarded to SIEM.	
SR/CR 2.9	Audit storage capacity	Confirm **auditd** log sizing/rotation (`max_log_file`, `num_logs`, `space_left_action`) and forwarding to the SIEM (audisp/rsyslog) so events are retained beyond local disk. **Ext. tools:** auditd.conf review; SIEM retention check.	Audit storage sized/rotated; events forwarded and retained.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.10	Response to audit processing failures	Confirm defined behavior on audit failure: auditd `disk_full_action` / `admin_space_left_action` (e.g. single/halt or syslog) per policy; SIEM alerts on forwarding loss. **Ext. tools:** auditd.conf (failure actions); SIEM agent-health alert.	Defined response to audit failure; alerting on forwarding loss.	
SR/CR 2.11	Timestamps	Time sync via `chrony`/`systemd-timesyncd`: `timedatectl` / `chronyc sources` to an authenticated NTP source. **Ext. tools:** `timedatectl`; Wireshark (NTP).	Accurate synchronized time; logs use synced time.	
SR/CR 2.12	Non-repudiation	Confirm attributable actions: no shared accounts, `sudo` with full command logging (auditd + `/var/log/auth.log`), privileged actions tied to a user. **Ext. tools:** sudoers review; ausearch for sudo/exec events.	Actions attributable to unique users; sudo/privileged use logged.	
HDR 2.13	Physical / diagnostic interfaces	Control physical/console access: GRUB password (`grub.cfg` superuser+password), disable single-user/recovery without auth, lock UEFI boot order + password, disable unused serial/console. **Ext. tools:** grub password check; UEFI/boot review; physical inspection.	Console/boot/diagnostic interfaces controlled; boot password set.	HDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 3.1	Communication integrity	Only encrypted services (SSH/TLS); confirm telnet/FTP/rsh removed (`ss -tlnp`); SSH strong ciphers/KEX (`sshd -T | grep -E "ciphers|kexalgorithms|macs"`). **Ext. tools:** ssh-audit; Nmap; `ss -tlnp`	Only encrypted protocols listen; strong SSH crypto; cleartext services gone.	
SR/HDR 3.2	Protection from malicious code	**AppArmor** enforcing (`aa-status`); signed APT repos only (`/etc/apt/sources.list*`, GPG keys); package integrity (`debsums -s`); optional ClamAV. No untrusted PPAs. **Ext. tools:** Lynis; `debsums`; OpenSCAP.	AppArmor enforcing; only signed packages; integrity verified.	HDR-specific.
SR/CR 3.3	Security functionality verification	Re-verify hardening after change with **OpenSCAP** against a CIS/STIG profile (`oscap xccdf eval`), plus `lynis audit system`; confirm no drift in services/AppArmor/firewall. **Ext. tools:** OpenSCAP (oscap) vs CIS/STIG; Lynis.	Configuration matches the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	**UEFI Secure Boot** (`mokutil --sb-state`); signed kernel/modules; file-integrity monitoring with **AIDE** (`aide --check`); GRUB password. **Ext. tools:** `mokutil --sb-state`; AIDE; OpenSCAP.	Secure Boot on; signed kernel/modules; file integrity monitored.	HDR-specific.
SR/CR 3.5	Input validation	For exposed services confirm robustness to malformed input; kernel/userspace mitigations on (ASLR, stack protector, seccomp for daemons); fuzz exposed protocol services in a lab. **Ext. tools:** sysctl kernel.randomize_va_space; protocol fuzzer (ISOLATED).	Mitigations on; no crash on malformed input to exposed services.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm graceful failure: core dumps disabled/restricted (`ulimit -c 0` / coredump.conf), no sensitive data in service logs, services restart cleanly (systemd Restart=). **Ext. tools:** coredump / limits review; journalctl for leaks.	Graceful error handling; no sensitive info leak.	
SR/CR 3.8	Session integrity	Confirm session integrity — sessions resist replay/hijack; no unauthenticated session path remains. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Session integrity verified individually.	
SR/CR 3.9	Protection of audit information	Protect audit logs: `/var/log/audit` restricted (0640 root), auditd immutable mode (`-e 2`), forward to a write-once SIEM so local tampering cannot erase the trail. **Ext. tools:** ls -l /var/log/audit; auditctl -s (enabled 2); SIEM immutability.	Audit records protected from unauthorized read/modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
HDR 3.10	Support for updates	Patching via `apt` / **unattended-upgrades** (`/etc/apt/apt.conf.d/50unattended-upgrades`); confirm current (`apt list --upgradable`) and Livepatch (kernel) where used. **Ext. tools:** `apt list --upgradable`; Nessus (missing patches).	Signed updates applied promptly; auto-update for security patches.	HDR-specific.
HDR 3.11	Physical / removable media	Restrict USB/removable media (udev rules / `USBGuard`); GRUB + UEFI password; disable boot from USB. LUKS protects at rest. **Ext. tools:** Config review; physical inspection.	Removable media + boot controlled; disk encrypted.	HDR-specific.
HDR 3.12	Provisioning product-supplier roots of trust	Confirm **UEFI Secure Boot** with the distro shim signed by the Microsoft/Canonical chain; kernel modules signed; only signed bootloader/kernel run. **Ext. tools:** mokutil --sb-state; check signed kernel/modules.	Supplier root of trust intact; only signed boot/kernel code runs.	HDR-specific.
HDR 3.13	Provisioning asset-owner roots of trust	Confirm asset-owner trust anchors: owner-enrolled **MOK** keys for locally-built/signed modules, owner CA in the trust store, custom Secure Boot keys where used. **Ext. tools:** mokutil --list-enrolled; trust store review.	Asset-owner trust anchors provisioned and managed.	HDR-specific.
HDR 3.14	Integrity of the boot process	Confirm integrity of the boot process — only signed/verified firmware boots (device requirement). **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.4** above (shared steps); confirm this requirement individually and adjudicate it separately.	Integrity of the boot process verified individually.	HDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.1	Information confidentiality	**LUKS** full-disk encryption (`lsblk`, `cryptsetup status`); TLS in transit; correct permissions on sensitive files. **Ext. tools:** `cryptsetup status`; CIS scan.	Data-at-rest encrypted (LUKS) and in-transit (TLS).	
SR/CR 4.2	Information persistence	On decommission/reuse, sanitize storage: **LUKS** crypto-erase (destroy the key slots) or `shred`/`blkdiscard`; wipe swap; confirm no recoverable credentials/keys. **Ext. tools:** cryptsetup erase; shred/blkdiscard; verify.	Sensitive data purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Strong SSH/TLS ciphers; system-wide crypto policy (where available) set to a strong profile; disable weak protocols. **Ext. tools:** ssh-audit; sslscan (host TLS services).	Modern strong crypto; weak ciphers/protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 5.1	Network segmentation	**ufw**/nftables default-deny inbound with explicit allows: `ufw status verbose` / `nft list ruleset`; only required ports; host isolation where needed. **Ext. tools:** Nmap (open ports by segment); `ufw status`	Host firewall default-deny inbound; only required flows.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	On an OT host, remove/disable general-purpose comms (mail clients, IM, browsers) and enforce execution allow-listing + egress filtering so the host is not usable for person-to-person messaging. **Ext. tools:** Package inventory (dpkg -l); egress/proxy review.	No general-purpose person-to-person comms on the OT host.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR 5.4	Application partitioning	Separate roles/apps: least-privilege service accounts, **AppArmor** confinement per service, namespaces/containers or separate VMs per function so a compromise is contained. **Ext. tools:** aa-status; service/account separation review.	Applications/roles partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 6.1	Audit log accessibility	Logs in `journalctl`/`/var/log` accessible; forward rsyslog/journald + auditd to the SIEM; host agent (Wazuh/osquery/EDR). **Ext. tools:** SIEM check; syslog listener (`nc -lu 514`).	Logs accessible and forwarded to SIEM; host monitoring active.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: host firewall (**UFW/nftables**) limits exposure, kernel SYN-cookies and rate limits (`sysctl` net.* hardening), only required services listen. **Ext. tools:** ufw status / nft list ruleset; Nmap; load test (ISOLATED).	Attack surface minimized; host resists resource-exhaustion DoS.	
SR/CR 7.2	Resource management	Confirm resource controls: systemd **cgroup** limits (CPUQuota/MemoryMax/TasksMax), `/etc/security/limits.conf` (nproc/nofile), disk quotas, and monitoring. **Ext. tools:** systemctl show (resource limits); limits.conf review.	Resources bounded; no single-process exhaustion.	
SR/CR 7.3	Control system backup	Automated backups of config/data + tested restore; verify job success and integrity (`sha256sum`). **Ext. tools:** Backup review; lab restore.	Recent verified backup; restore tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Config settings baseline	Apply/verify the CIS/STIG baseline via OpenSCAP; document deviations. **Ext. tools:** `oscap xccdf eval --profile ds.xml`.	Host matches the CIS/STIG baseline; deviations documented.	
SR/CR 7.7	Least functionality	Remove unused packages/services: `systemctl list-unit-files --state=enabled`, `apt list --installed`; disable unneeded; close unused ports; no compilers/tools on production. **Ext. tools:** Lynis; Nmap (open ports); `ss -tlnp`	Only required packages/services/ports present.	
SR/CR 7.8	Component inventory	Capture OS/kernel/packages: `uname -a`, `lsb_release -a`, `dpkg -l`. **Ext. tools:** Inventory/EDR agent; ReadOnlyEnum.	Complete OS/kernel/package inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
OpenSCAP (oscap) + CIS-CAT / STIG Viewer	Baseline compliance (all)	`oscap xccdf eval --profile --results r.xml ssg-ubuntu-ds.xml`; review in STIG Viewer; drives most pass/fail evidence.	Authorized scan account.
Lynis	Host hardening audit (most rows)	`lynis audit system`; review warnings/suggestions for auth, sudo, SSH, AppArmor, services.	Read-only audit.
ssh-audit	SSH config & crypto (1.1, 3.1, 4.3)	`ssh-audit` ; confirm strong KEX/cipher/MAC and hardened `sshd_config`.	Read-only.
sslscan / testssl.sh	TLS strength of host services (4.3)	`sslscan :`; confirm TLS1.2/1.3 + strong ciphers.	Read-only.
auditd (ausearch / auditctl)	Audit rules & events (2.8)	`auditctl -l`; `ausearch -m USER_LOGIN,USER_CMD` to confirm events are captured.	Read-only.
AIDE / debsums	File & package integrity (3.2, 3.4)	`aide --check`; `debsums -s` to detect modified files/packages.	Read-only.
Nmap	Port/service exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p- -T2` ; scan by segment; confirm only required ports open, no telnet/FTP.	Tune timing on production.
Nessus / OpenVAS	Known-CVE vulnerability scan (3.2, general)	Authenticated scan for missing patches/CVEs; cross-check USN advisories.	ISOLATED/authorized.
Hydra / fail2ban-client	Lockout behavior (1.11)	Authorized repeated SSH logins to confirm `pam_faillock`/fail2ban; `fail2ban-client status sshd`.	ISOLATED/authorized only.
ReadOnlyEnum	Host/network enumeration (7.8)	Enumerate services/ports/config read-only.	Read-only.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.